



UNIVERSITÀ DEGLI STUDI DI SALERNO

Penetration Testing Report

Academy - Cybersecurity

Target: no_name

Gruppo 11

Emiddio Ferrentino - 0612708848

Daniele Manzo - 0612709599

Andrea Rossomando - 0612708971

A.A. 2025/2026

Sommario

Questo documento riporta i risultati dell'attività di Penetration Testing condotta dal Gruppo 11 sull'infrastruttura virtuale **no_name**, nell'ambito del corso di Cybersecurity Academy (A.A. 2025/2026). L'analisi ha seguito il **Framework Generale per il Penetration Testing (FGPT)** [1], articolandosi nelle fasi di *Information Gathering*, *Vulnerability Assessment*, *Target Exploitation* e *Privilege Escalation*.

Il presente *Penetration Testing Report* è destinato a un pubblico misto, dal management aziendale agli amministratori di sistema, e si articola in cinque sezioni principali: un *Executive Summary* sintetico rivolto alla dirigenza, un *Vulnerability Report* che descrive le criticità rilevate, un *Remediation Report* con le raccomandazioni correttive, un *Findings Summary* di sintesi e un *Detailed Summary* con l'analisi tecnica completa. La documentazione operativa dei test (comandi eseguiti, output ottenuti, screenshot) è raccolta nel documento separato *Metodologie Utilizzate PT*, che accompagna questa relazione.

Indice

1	Executive Summary	4
1.1	Scope del test	4
1.2	Risultati ottenuti	4
1.3	Problematiche rilevate	4
1.4	Contromisure	5
1.5	Analisi del rischio	5
1.5.1	Valutazione	5
1.5.2	Riduzione	5
2	Engagement Highlights	6
2.1	Accordi preliminari	6
2.2	Requisiti legali e operativi	6
2.3	Modalità di esecuzione del Penetration Testing	6
2.4	Metodologia adottata	6
2.5	Date di inizio e fine attività	7
2.6	Obiettivi del test	7
2.7	Ruoli, obblighi e responsabilità	7
3	Vulnerability Report	8
3.1	Command Injection	8
3.1.1	Descrizione della vulnerabilità	8
3.1.2	Impatto sulla sicurezza	8
3.1.3	Valutazione esposizione	8
3.2	Local Privilege Escalation	8
3.2.1	Descrizione della vulnerabilità	8
3.2.2	Impatto sulla sicurezza	9
3.2.3	Valutazione esposizione	9
3.3	CUPS Vulnerability	9
3.3.1	Descrizione della vulnerabilità	9
3.3.2	Impatto sulla sicurezza	9
3.3.3	Valutazione esposizione	9
3.4	Security Misconfiguration	9
3.4.1	Descrizione della vulnerabilità	9
3.4.2	Impatto sulla sicurezza	10
3.4.3	Valutazione esposizione	10
3.5	Sensitive Data Exposure	10
3.5.1	Descrizione della vulnerabilità	10
3.5.2	Impatto sulla sicurezza	10
3.5.3	Valutazione esposizione	10

3.6	Information Disclosure	10
3.6.1	Descrizione della vulnerabilità	10
3.6.2	Impatto sulla sicurezza	11
3.6.3	Valutazione esposizione	11
4	Remediation Report	12
4.1	Obiettivo	12
4.2	Raccomandazioni di sicurezza	12
4.2.1	VULN-01: Command Injection	12
4.2.2	VULN-02: Local Privilege Escalation	12
4.2.3	VULN-03: CUPS Vulnerability	13
4.2.4	VULN-04: Security Misconfiguration (Header HTTP)	13
4.2.5	VULN-05: Sensitive Data Exposure	13
4.2.6	VULN-06: Information Disclosure (ICMP/TCP Timestamp)	13
5	Findings Summary	15
5.1	Convenzioni e catalogazione	15
5.2	Dettaglio dei risultati	15
5.3	Grafici e visualizzazioni	16
5.4	Focus tecnico	16
5.5	Supporto alla remediation	17
6	Detailed Summary	18
6.1	VULN-01: Command Injection	18
6.2	VULN-02: Local Privilege Escalation	19
6.3	VULN-03: CUPS Unauthenticated Remote Registration	19
6.4	VULN-04: Security Misconfiguration	20
6.5	VULN-05: Sensitive Data Exposure	21
6.6	VULN-06: Information Disclosure	21
7	Bibliografia	23

Capitolo 1

Executive Summary

Questa sezione presenta una sintesi non tecnica dello stato di sicurezza della macchina virtuale **no_name**, rivolta al management e ai decisori del committente. Vengono evidenziati i rischi di business derivanti dalle vulnerabilità identificate e le azioni correttive prioritarie raccomandate.

1.1 Scope del test

Il perimetro dell'attività è stato limitato alla macchina virtuale **no_name** e ai servizi da essa esposti. L'obiettivo era simulare un attacco esterno realistico per identificare le vulnerabilità presenti, documentarne l'impatto e valutarne lo sfruttamento concreto nelle condizioni operative dell'ambiente di laboratorio.

1.2 Risultati ottenuti

L'attività di Penetration Testing ha portato alla **compromissione completa del bersaglio**. Il team è riuscito a ottenere un accesso iniziale al sistema sfruttando una vulnerabilità dell'applicazione web e, attraverso una catena di passaggi successivi, ad acquisire i privilegi di amministratore (*root*). Nello stato attuale, l'infrastruttura risulterebbe esposta a un rischio di compromissione critico qualora fosse messa in produzione senza interventi correttivi.

1.3 Problematiche rilevate

Le criticità che hanno portato alla compromissione derivano da due macro-aree:

1. Debolezze applicative:

- **Validazione degli input:** Sono state individuate gravi carenze nella validazione degli input nell'applicazione web, che hanno permesso a un utente non autorizzato di eseguire comandi arbitrari sul sistema operativo del server.
- **Mancanza di policy di sicurezza HTTP:** L'assenza degli *header* di sicurezza standard espone l'interfaccia a manipolazioni lato client che potrebbero indurre operatori legittimi a eseguire azioni non volute.

2. Misconfigurazioni di sistema e di rete:

- **Servizi superflui esposti:** Il sistema mantiene attivi e accessibili dalla rete servizi non necessari all'erogazione dell'applicazione web, alcuni dei quali affetti da vulnerabilità note pubblicamente.

- **Esposizione di credenziali e informazioni sensibili:** Sono state riscontrate credenziali memorizzate in chiaro all'interno del file system, oltre a riferimenti a risorse riservate nascosti in modo inadeguato all'interno di contenuti pubblici.
- **Configurazione di rete eccessivamente permissiva:** L'host risponde a richieste diagnostiche che rivelano involontariamente informazioni sul proprio stato operativo.

1.4 Contromisure

Per riportare l'asset a un livello di sicurezza adeguato si raccomanda di intervenire tempestivamente sulle seguenti aree:

- Implementare controlli rigorosi sulla validazione di tutti i dati in ingresso all'applicazione web.
- Disabilitare i servizi di sistema non necessari all'erogazione delle funzionalità previste.
- Applicare il principio del *minimo privilegio* (Least Privilege) nella gestione delle autorizzazioni e dei permessi locali.
- Rimuovere ogni traccia di credenziali memorizzate in chiaro e bonificare le risorse pubbliche da informazioni sensibili occultate.

1.5 Analisi del rischio

1.5.1 Valutazione

Rischio Attuale

Il rischio complessivo associato all'asset **no_name** è classificato come **CRITICO**. Le vulnerabilità identificate consentono a un attaccante esterno, privo di credenziali, di ottenere l'accesso al sistema e acquisire progressivamente i privilegi di amministratore. Da questa posizione, un attaccante potrebbe esfiltrare dati riservati, alterare configurazioni e log di sistema o utilizzare la macchina compromessa come punto di partenza per attacchi laterali verso altri host della rete.

1.5.2 Riduzione

Rischio Residuo Atteso

L'applicazione delle *remediation* suggerite nel presente documento riduce significativamente la superficie d'attacco. Mitigando le vulnerabilità applicative e correggendo le configurazioni di sistema, il rischio residuo è atteso al livello **BASSO**, compatibile con i normali requisiti operativi.

Capitolo 2

Engagement Highlights

2.1 Accordi preliminari

Le attività di Penetration Testing sono state concordate e autorizzate nell'ambito del corso di Cybersecurity Academy (A.A. 2025/2026). Il team di analisi, composto dai membri del Gruppo 11, ha ricevuto il mandato esclusivo di valutare l'asset `no_name` operando in un ambiente di laboratorio isolato.

2.2 Requisiti legali e operativi

Tutte le operazioni offensive sono state condotte nel rispetto del perimetro autorizzato. Non sono stati effettuati attacchi contro asset diversi dal target, e gli indirizzi IP estranei al perimetro definito sono stati esclusi da qualsiasi attività di analisi attiva. Le metodologie applicate sono coerenti con quanto previsto dal FGPT e con le *Rules of Engagement* formalizzate prima dell'inizio dei test. Al termine delle attività di verifica, il team ha inoltre provveduto a effettuare una rigorosa operazione di *cleanup*, rimuovendo gli artefatti temporanei creati durante l'attacco (come la *pipe* di sistema utilizzata per la *reverse shell*) per restituire l'ambiente nel suo stato di integrità originale.

2.3 Modalità di esecuzione del Penetration Testing

L'attività è stata eseguita secondo un approccio *Black-Box*. Le uniche informazioni fornite dal creatore della macchina `no_name` sono le seguenti:

- La macchina è del tipo *Capture The Flag* (CTF) e segue il modello *Boot2Root*.
- È prevista una fase di Privilege Escalation per il raggiungimento degli obiettivi.

Al di fuori di queste indicazioni, il team non disponeva di alcuna conoscenza pregressa sul funzionamento interno del sistema, sul codice sorgente o sulle configurazioni di rete, simulando così le condizioni operative di un attaccante esterno.

2.4 Metodologia adottata

L'intero processo di valutazione è stato guidato dal **Framework Generale per il Penetration Testing (FGPT)** [1]. Questo standard ha garantito un approccio strutturato e riproducibile, articolato nelle fasi di *Information Gathering*, *Vulnerability Assessment*, *Target Exploitation* e *Privilege Escalation*. La documentazione operativa di ciascuna fase, comprensiva di comandi e output, è riportata nel documento separato *Metodologie Utilizzate PT*.

2.5 Date di inizio e fine attività

Le operazioni di test, comprensive di ricognizione, exploitation e stesura della documentazione, si sono svolte dal 19 maggio 2026 al 16 giugno 2026.

2.6 Obiettivi del test

L'obiettivo dell'ingaggio è duplice:

1. Valutare il grado di sicurezza dell'infrastruttura, fornendo una panoramica della tenuta del sistema e degli applicativi sottostanti in un possibile scenario di attacco esterno.
2. Produrre un report analitico che fornisca ai responsabili IT le indicazioni tecniche per la risoluzione delle vulnerabilità identificate.

2.7 Ruoli, obblighi e responsabilità

- **Gruppo 11:** responsabile della conduzione tecnica dei test, dell'identificazione delle vulnerabilità e della stesura del presente report.
- **Committente:** responsabile della fornitura dell'ambiente di test e della valutazione finale delle metodologie applicate e dei risultati ottenuti.

Capitolo 3

Vulnerability Report

In questa sezione vengono descritte le vulnerabilità identificate durante l'attività di Penetration Testing. Per ciascuna criticità sono forniti una descrizione generale, l'impatto sulla sicurezza e una valutazione dell'esposizione, al fine di rendere comprensibili i rischi operativi anche a un pubblico non strettamente tecnico. La severità di ciascuna vulnerabilità è riportata accanto al titolo della relativa sezione secondo la scala qualitativa definita nel Findings Summary (cfr. §5.1).

3.1 VULN-01: Command Injection

CRITICAL

3.1.1 Descrizione della vulnerabilità

È stata individuata una vulnerabilità di tipo *Command Injection* [6] all'interno dell'applicazione web, nello specifico nella pagina di amministrazione `/superadmin.php`. La pagina contiene un form che accetta un input utente (un indirizzo IP) per effettuare un test di connettività tramite `ping`, ma non implementa meccanismi di validazione e filtraggio sufficienti a bloccare richieste contenenti metacaratteri di shell.

3.1.2 Impatto sulla sicurezza

Sfruttando la falla, un attaccante può iniettare comandi arbitrari del sistema operativo all'interno della richiesta e indurre il web server a eseguirli con i privilegi del processo che ospita l'applicazione.

3.1.3 Valutazione esposizione

Sfruttando questa *injection*, l'attaccante ottiene una *reverse shell* silente che garantisce un accesso diretto al file system e alle logiche interne del server. Questa intrusione primaria scavalca le difese perimetrali e stabilisce il *foothold* necessario per intraprendere operazioni di profilazione locale e movimento laterale.

3.2 VULN-02: Local Privilege Escalation (Sudoers Misconfiguration)

CRITICAL

3.2.1 Descrizione della vulnerabilità

Durante la fase di *post-exploitation* sono state rilevate due criticità a livello di sistema operativo locale. La prima è la presenza di un file nascosto contenente in chiaro la password dell'utente `haclabs`. La seconda è una configurazione del file `/etc/sudoers` che autorizza il medesimo utente a eseguire il binario `/usr/bin/find` con privilegi di `root` e senza richiesta di password (direttiva `NOPASSWD`).

3.2.2 Impatto sulla sicurezza

La combinazione delle due misconfigurazioni consente a un attaccante che abbia ottenuto un accesso iniziale al sistema (ad esempio tramite la VULN-01) di elevare i propri privilegi fino al livello amministrativo. Il binario `find`, infatti, dispone nativamente del parametro `-exec`, che ne permette l'utilizzo per generare una shell di sistema autonoma.

3.2.3 Valutazione esposizione

Questa vulnerabilità rappresenta l'anello finale della catena di attacco. Sfruttando i privilegi delegati, l'attaccante assume il controllo assoluto dell'infrastruttura, acquisendo la facoltà di leggere chiavi di crittografia, manipolare i demoni di sistema o alterare i file di log per neutralizzare le verifiche forensi.

3.3 VULN-03: CUPS Unauthenticated Remote Registration (CVE-2024-47176) HIGH

3.3.1 Descrizione della vulnerabilità

Durante la fase di analisi e mappatura dell'infrastruttura è stata rilevata l'esposizione del servizio di stampa di sistema **CUPS**, nello specifico del demone `cups-browsed` in ascolto sulla porta 631 UDP. Il servizio è affetto dalla vulnerabilità pubblica CVE-2024-47176 [2], dovuta al fatto che il demone accetta e processa richieste di registrazione di stampanti senza alcuna autenticazione o verifica dell'identità del mittente.

3.3.2 Impatto sulla sicurezza

Un attaccante può inviare pacchetti IPP contraffatti annunciandosi come stampante fittizia sotto il proprio controllo. Successivamente, qualora un utente locale del sistema target avvii un *print job* verso tale stampante, il sistema processa direttive PPD malevole che possono portare all'esecuzione di codice remoto (RCE) nel contesto del servizio di stampa.

3.3.3 Valutazione esposizione

L'apertura di un servizio di stampa di sistema verso l'esterno espone il server ad attacchi mirati indipendenti dall'applicazione web. È importante segnalare, tuttavia, che nelle condizioni specifiche dell'ambiente di test la *kill-chain* di sfruttamento non è risultata completabile: il trigger finale (l'avvio di un *print job* da parte di un utente locale) non è simulabile in un laboratorio privo di utenti reali. La vulnerabilità è quindi confermata architetturalmente e mantiene la severity **HIGH** ai fini della classificazione formale, pur essendo stata classificata come non sfruttabile nello scenario operativo specifico.

3.4 VULN-04: Security Misconfiguration (Header HTTP Mancanti) MEDIUM

3.4.1 Descrizione della vulnerabilità

L'analisi automatizzata delle configurazioni del web server ha evidenziato la mancanza di diverse intestazioni (*header*) di sicurezza HTTP. In particolare, il server non implementa le policy **X-Frame-Options** (o equivalente direttiva CSP `frame-ancestors`), **Content-Security-Policy** (CSP), **Strict-Transport-Security** (HSTS), **X-Content-Type-Options**, **Permissions-Policy** e **Referrer-Policy**. Queste intestazioni rappresentano lo standard moderno per istruire i browser su come proteggere i contenuti del sito web e i propri utenti.

3.4.2 Impatto sulla sicurezza

La mancanza delle intestazioni di sicurezza espone gli utenti finali dell'applicazione web a manipolazioni lato client. Sfruttando questa debolezza, soggetti esterni possono forzare il browser delle vittime a eseguire azioni non autorizzate a loro nome o a rivelare i dati immessi nel portale aziendale.

3.4.3 Valutazione esposizione

L'esposizione diretta dell'infrastruttura server è nulla, poiché l'attacco si concretizza unicamente sul dispositivo del fruitore del servizio. Tuttavia, il rischio di business è considerevole: eventuali frodi o furti di sessione minano irrimediabilmente l'affidabilità, la fiducia e la reputazione del servizio offerto dall'organizzazione.

3.5 VULN-05: Sensitive Data Exposure (Credenziali Occultate) **MEDIUM**

3.5.1 Descrizione della vulnerabilità

L'ispezione dei contenuti statici e multimediali dell'applicazione ha rivelato una gestione impropria delle informazioni riservate. All'interno di un'immagine pubblicata sulla pagina di amministrazione primaria (`/admin`) è stata occultata, tramite tecniche di steganografia, una *passphrase* in chiaro. Il dato nascosto rivela l'indirizzo esatto di un pannello amministrativo di livello superiore non documentato (`superadmin.php`). A queste si aggiunge la presenza di una password in chiaro in un file di sistema (`/usr/share/hidden/.passwd`), riferita all'utente `haclabs` e già descritta come componente della VULN-02.

3.5.2 Impatto sulla sicurezza

Il mascheramento di dati critici all'interno di asset pubblici, in assenza di robusti controlli crittografici o autorizzativi, costituisce una grave negligenza procedurale. Questa problematica viola i principi fondamentali della corretta gestione dei segreti aziendali, esponendo informazioni che dovrebbero rimanere strettamente confidenziali.

3.5.3 Valutazione esposizione

L'errata gestione dei segreti agisce come acceleratore per attacchi complessi. Rivelare l'esistenza di interfacce vulnerabili tramite la steganografia e abbandonare credenziali di sistema in directory interrogabili fornisce a un attaccante esterno una mappa esatta dei vettori critici, bypassando la necessità di lunghi *bruteforce* e garantendo movimenti laterali rapidi.

3.6 VULN-06: Information Disclosure (Timestamp e File di Default) **LOW**

3.6.1 Descrizione della vulnerabilità

Durante la fase di enumerazione condotta tramite lo scanner OpenVAS è emerso che il sistema operativo del bersaglio risponde attivamente alle richieste di *Timestamp* inoltrate sui protocolli ICMP e TCP. In aggiunta alle metriche temporali, l'enumerazione del server web ha rivelato l'esposizione pubblica di file di default dell'installazione di Apache (nello specifico la risorsa `/icons/README`), che conferma ulteriormente la mancanza di un *hardening* di base del servizio.

3.6.2 Impatto sulla sicurezza

La problematica è legata esclusivamente alla divulgazione passiva di informazioni diagnostiche (*Information Disclosure*), e non comporta modifiche all'integrità dei dati, né iniezioni logiche.

3.6.3 Valutazione esposizione

Conoscere l'uptime esatto di una macchina permette a un attaccante di dedurre quali *patch* di sicurezza del kernel potrebbero mancare, orientando i tentativi di attacco futuri con precisione millimetrica e limitando il tempo necessario per la profilazione dell'obiettivo.

Capitolo 4

Remediation Report

Questa sezione è destinata al **management e ai responsabili delle policy di sicurezza**. L'obiettivo è tradurre le criticità tecniche emerse in raccomandazioni di sicurezza strutturate (misure correttive e migliorative), in modo da favorire una rapida riduzione del rischio e un rafforzamento complessivo dell'asset. Le azioni correttive sono presentate in ordine di priorità discendente.

4.1 Obiettivo

L'obiettivo della *remediation* è eliminare i vettori di compromissione diretta (Command Injection e configurazione `sudo` permissiva) che pongono l'infrastruttura a rischio critico. Contestualmente, si mira a rafforzare la postura difensiva generale eliminando le fughe di informazioni e implementando le *best practice* di configurazione web.

4.2 Raccomandazioni di sicurezza

4.2.1 VULN-01: Command Injection

- **Validazione dell'input:** sostituire l'attuale meccanismo basato su *blacklist* con un'*allowlist* di formato. Per gli input attesi come indirizzi IP, utilizzare funzioni di validazione native e sicure (es. `filter_var($ip, FILTER_VALIDATE_IP)` in PHP) prima di processare il valore.
- **Eliminazione delle chiamate dirette alla shell:** sostituire `shell_exec()` con `proc_open()` accompagnato da `escapeshellarg()`, oppure con librerie native del linguaggio che non richiedano l'invocazione di una shell di sistema.
- **Principio del minimo privilegio:** verificare che l'utente sotto cui gira il web server (`www-data`) operi in un ambiente isolato (es. *chroot* jail o container) e non disponga di permessi di lettura/scrittura al di fuori della propria *directory* operativa.

4.2.2 VULN-02: Local Privilege Escalation

- **Bonifica delle credenziali:** rimuovere il file `/usr/share/hidden/.passwd` contenente la password in chiaro ed effettuare un reset forzato della password dell'account `haclabs`.
- **Hardening del file Sudoers:** modificare il file `/etc/sudoers` esclusivamente tramite il comando `visudo`, rimuovendo la direttiva `NOPASSWD` associata al binario `find` per l'utente `haclabs`.

- **Audit dei binari GTFOBins:** condurre una revisione completa di tutti i binari concessi in esecuzione via `sudo`, evitando di delegare permessi elevati a programmi (come `find`, `tar`, `awk`, `vim`) noti per disporre di funzionalità native sfruttabili per lo *spawn* di shell.

4.2.3 VULN-03: CUPS Vulnerability

- **Disabilitazione dei servizi superflui:** arrestare e disabilitare definitivamente il demone `cups-browsed` tramite il gestore di servizi di sistema (es. `systemctl disable cups-browsed.service`), poiché l'erogazione di servizi di stampa non è pertinente alla funzione di web server svolta dall'host.
- **Hardening di rete:** configurare regole del *firewall* (es. `iptables` o `ufw`) per bloccare tutto il traffico UDP in ingresso sulla porta 631 proveniente da reti non fidate.
- **Patching del sistema:** applicare gli aggiornamenti di sicurezza distribuiti dal fornitore del sistema operativo per risolvere la CVE-2024-47176 a livello di pacchetto.

4.2.4 VULN-04: Security Misconfiguration (Header HTTP)

- **Prevenzione anti-framing:** configurare il web server per includere l'intestazione `X-Frame-Options: DENY` (o, in alternativa, la direttiva CSP `frame-ancestors 'none'`) in tutte le risposte HTTP.
- **Content Security Policy:** implementare una policy CSP restrittiva che autorizzi esclusivamente l'esecuzione di risorse provenienti dal dominio locale (es. `default-src 'self'`).
- **Header complementari:** abilitare `Strict-Transport-Security` (HSTS), `X-Content-Type-Options: nosniff`, `Referrer-Policy` e `Permissions-Policy` per completare l'*hardening* HTTP del server.
- **Aggiornamento di Apache:** aggiornare il web server alla versione corrente, dato che la 2.4.29 è significativamente obsoleta rispetto alle release supportate.

4.2.5 VULN-05: Sensitive Data Exposure

- **Bonifica delle risorse pubbliche:** rimuovere le immagini contenenti dati steganograficamente occultati e sottoporre a revisione tutti i contenuti multimediali esposti sul web server.
- **Abbandono della Security through Obscurity:** smettere di basare la sicurezza di una pagina (come `superadmin.php`) sulla sola segretezza dell'URL, e implementare un controllo di accesso esplicito.
- **Controllo degli accessi:** introdurre un meccanismo di autenticazione robusto (credenziali forti, gestione sicura delle sessioni, eventualmente autenticazione a più fattori) per qualunque area amministrativa del sito.
- **Gestione dei segreti:** adottare strumenti dedicati (es. `vault`) per la memorizzazione di credenziali e configurazioni sensibili, eliminando ogni traccia di password in chiaro dal file system e dai commenti del codice sorgente.

4.2.6 VULN-06: Information Disclosure (ICMP/TCP Timestamp)

- **Disabilitazione ICMP Timestamp:** configurare le regole `iptables` per scartare in modo silente i pacchetti ICMP di tipo 13 (Timestamp Request) e 14 (Timestamp Reply) in ingresso.
- **Disabilitazione TCP Timestamp:** valutare la disabilitazione dell'estensione TCP Timestamp (`net.ipv4.tcp_timestamps` in `sysctl.conf`) se non strettamente necessaria.

- **Rimozione file di default:** Rimuovere o disabilitare l'accesso alla directory `/icons/` e ad altri file di installazione predefiniti di Apache non necessari all'applicativo.
- **Minimizzazione del banner:** effettuare una revisione delle risposte HTTP del server per evitare la divulgazione di informazioni di versione (es. `Apache/2.4.29 (Ubuntu)`) tramite la direttiva `ServerTokens Prod`.

Capitolo 5

Findings Summary

Questa sezione espone le evidenze emerse dall'attività di *penetration testing*, fungendo da ponte tra la visione manageriale dei capitoli precedenti e l'analisi tecnica del *Detailed Summary*.

5.1 Convenzioni e catalogazione

Per garantire uniformità di lettura e classificazione tecnica in tutto il documento, la severità di ciascuna vulnerabilità è stata definita secondo una scala qualitativa standard di settore, allineata alle linee guida OWASP [5]. Tale scala riflette l'impatto potenziale, l'esposizione al rischio e la facilità di sfruttamento.

Livello di Severità	Descrizione e Impatto Operativo
CRITICAL	Vulnerabilità critica che permette la compromissione totale del sistema o l'esecuzione di codice remoto (RCE) in modo diretto, senza necessità di privilegi pregressi. L'intervento di risoluzione deve essere immediato.
HIGH	Vulnerabilità grave che espone servizi di sistema critici o permette un accesso non autorizzato di alto livello, agevolando l'attaccante nella compromissione dell'asset.
MEDIUM	Vulnerabilità che richiede interazione da parte dell'utente, configurazioni specifiche o che espone dati sensibili (es. credenziali, path nascosti) utilizzabili come vettore per attacchi successivi.
LOW	Vulnerabilità legata alla divulgazione di informazioni diagnostiche o a misconfigurazioni marginali. Presenta un basso impatto diretto sull'integrità del sistema, ma facilita le fasi di ricognizione.

5.2 Dettaglio dei risultati

La seguente tabella riepiloga le evidenze emerse dall'attività, aggregate e ordinate per livello di criticità decrescente.

ID	Vulnerabilità	Severità
VULN-01	Command Injection (<code>superadmin.php</code>)	CRITICAL
VULN-02	Local Privilege Escalation	CRITICAL
VULN-03	CUPS Unauthenticated RCE (CVE-2024-47176)	HIGH
VULN-04	Security Misconfiguration (Assenza Header HTTP)	MEDIUM
VULN-05	Sensitive Data Exposure (Credenziali Occultate)	MEDIUM
VULN-06	Information Disclosure (ICMP/TCP Timestamp)	LOW

Tabella 5.1: Riepilogo delle vulnerabilità identificate e relativa classificazione.

5.3 Grafici e visualizzazioni

Per offrire una rapida percezione dello stato di salute dell’infrastruttura, il seguente grafico illustra la distribuzione quantitativa delle vulnerabilità identificate, raggruppate per livello di severità.

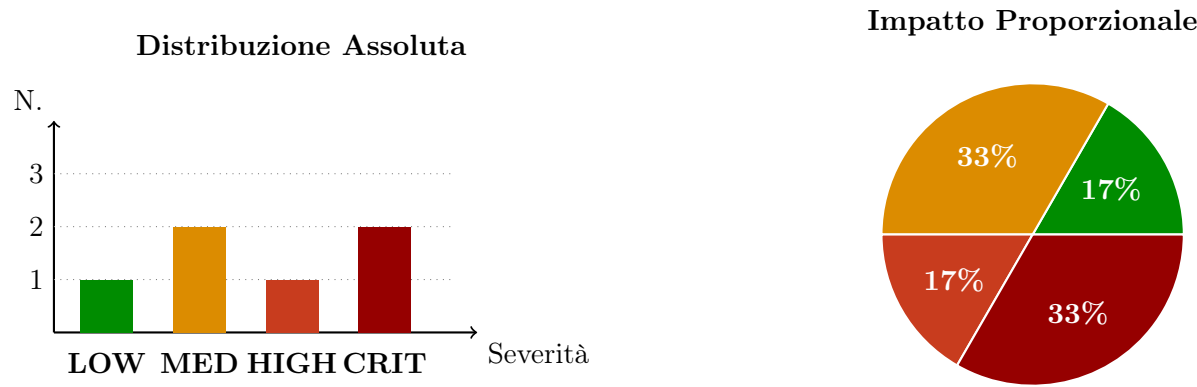


Figura 5.1: Distribuzione assoluta e proporzionale delle vulnerabilità rilevate, suddivise per livello di criticità.

Le metriche evidenziano una distribuzione bilanciata tra le fasce di severità: il 50% delle vulnerabilità ricade nelle fasce di rischio medio-basso, mentre la presenza di vulnerabilità di grado **HIGH** e **CRITICAL** (il restante 50%) sbilancia significativamente il profilo di rischio complessivo verso una compromissione potenziale dell’asset.

5.4 Focus tecnico

La sicurezza dell’infrastruttura è stata compromessa non da una singola falla isolata ma da una catena di attacco strutturata (*kill chain*). L’esposizione di credenziali tramite steganografia (VULN-05) ha fornito l’accesso a un’area non documentata che, a causa dell’assenza di sanitizzazione degli input (VULN-01), ha permesso di instaurare una *reverse shell*. La successiva combinazione di una password memorizzata in chiaro e di una configurazione `sudo` permissiva (VULN-02) ha consentito di scalare i privilegi fino

al livello amministrativo. Parallelamente, l'infrastruttura di rete si è dimostrata vulnerabile a causa dell'esposizione di un servizio di sistema non strettamente necessario (VULN-03) e di una configurazione di rete eccessivamente verbosa (VULN-06).

5.5 Supporto alla remediation

Si raccomanda agli amministratori di sistema di intervenire a due livelli paralleli:

1. **Livello infrastrutturale:** isolare il web server tramite tecnologie di containerizzazione (es. Docker) o *chroot*; implementare regole **iptables** con policy *default-deny* che chiudano tutte le porte UDP/TCP non strettamente necessarie al traffico HTTP (in particolare la porta 631 del demone CUPS); disabilitare la divulgazione dei Timestamp ICMP/TCP modificando i parametri **sysctl** e applicando le opportune regole di firewall.
2. **Livello applicativo:** riscrivere le funzioni PHP che gestiscono l'input in **superadmin.php** utilizzando **filter_var()** per la validazione e **proc_open()** con **escapeshellarg()** al posto delle chiamate dirette a **shell_exec()**; rimuovere dalle risorse pubbliche tutte le immagini contenenti dati steganograficamente occulti e introdurre un meccanismo di autenticazione esplicito per ogni area amministrativa del sito.

Capitolo 6

Detailed Summary

In questa sezione viene presentata l'analisi tecnica dettagliata per ogni vulnerabilità rilevata, organizzata in quattro punti: modalità di scoperta, origini e cause, rischi e impatti sull'asset, contromisure tecniche. Per la documentazione operativa dei test (comandi, output, screenshot) si rimanda al documento *Metodologie Utilizzate PT*.

6.1 VULN-01: Command Injection

Modalità di scoperta:

La vulnerabilità è stata identificata durante l'ispezione manuale del form della pagina `superadmin.php`. Dopo aver verificato che la pagina invoca effettivamente il comando `ping` verso l'IP fornito, sono stati condotti tentativi di concatenazione di comandi tramite metacaratteri shell. I primi test con `&&` e `;` sono stati intercettati da un filtro lato server; l'utilizzo del metacarattere *pipe* (`|`) ha invece aggirato il filtro, permettendo di leggere il sorgente PHP della pagina e confermare la presenza della vulnerabilità.

Origini e Cause:

L'origine della vulnerabilità risiede in due problemi del codice PHP che gestisce la funzione di diagnostica di rete. In primo luogo, l'input utente è filtrato tramite una *blacklist* implementata con `str_replace()` che rimuove un insieme finito di stringhe vietate (tra cui `nc` e `bin`) ma omette metacaratteri fondamentali come `|` e meccanismi di *Command Substitution* come i *backticks*. In secondo luogo, l'input parzialmente filtrato viene passato direttamente alla funzione `shell_exec()` senza alcuna sanitizzazione strutturale.

Rischi e impatti sull'asset:

La mancata sanitizzazione consente a un attaccante di concatenare istruzioni arbitrarie alla chiamata `ping` eseguita dal server. Durante il test, il team ha sfruttato la combinazione di *Command Substitution* (``...``) e codifica Base64 per aggirare il filtro sui caratteri vietati e instaurare una *reverse shell* verso la macchina attaccante, ottenendo l'accesso interattivo al file system locale ed l'esecuzione di comandi eseguiti con i privilegi dell'utente applicativo `www-data`.

Contromisure tecniche adeguate:

A livello di codice sorgente è necessario eliminare le chiamate dirette alla shell. Se l'esecuzione del comando `ping` è effettivamente richiesta, l'input dell'utente deve essere validato preventivamente come indirizzo IP legittimo tramite funzioni native (es. `filter_var($ip, FILTER_VALIDATE_IP)` in PHP) e la chiamata deve essere effettuata tramite `proc_open()` con argomenti opportunamente escapati da `escapeshellarg()`, evitando di costruire la stringa di comando concatenando diret-

tamente l'input dell'utente. È inoltre raccomandato sostituire l'approccio basato su *blacklist* con un'*allowlist* di formato (CWE-78 [3]).

6.2 VULN-02: Local Privilege Escalation

Modalità di scoperta:

La vulnerabilità è stata identificata nella fase di enumerazione locale successiva all'ottenimento della *reverse shell*. L'esplorazione delle directory accessibili dal contesto `www-data` ha permesso di individuare il file nascosto `/usr/share/hidden/.passwd`, contenente in chiaro la password dell'utente `haclabs`. Dopo aver effettuato il movimento laterale verso questo utente tramite `su`, l'esecuzione di `sudo -l` ha rivelato la presenza di privilegi anomali assegnati al binario `find`.

Origini e Cause:

La criticità deriva dalla combinazione di due errori di configurazione. Il primo è la memorizzazione in chiaro di una password in un file del file system, in violazione delle best practice di gestione dei segreti. Il secondo è la concessione del permesso `NOPASSWD` sul binario `/usr/bin/find` per l'utente `haclabs`, ignorando che tale binario rientra nella categoria dei *GTFOBins* [4]: programmi legittimi del sistema operativo che, in determinate condizioni, possono essere abusati per ottenere privilegi superiori. Nello specifico, `find` dispone del parametro `-exec`, che consente l'esecuzione di un comando arbitrario su ogni file individuato.

Rischi e impatti sull'asset:

Tramite la direttiva `sudo` compromessa, l'attaccante ha la facoltà di eseguire `/usr/bin/find` e passare ad esso il comando `-exec "/bin/bash"`. Questo escamotage causa lo spawn istantaneo di una shell interattiva che eredita i privilegi del comando padre, ovvero `root`. A questo punto, il controllo tecnico sull'host e su tutti i file di sistema è totale.

Contromisure tecniche adeguate:

È necessario intervenire su entrambi i piani della vulnerabilità: rimuovere il file `/usr/share/hidden/.passwd`, effettuare il reset della password dell'utente `haclabs` e revocare l'autorizzazione `NOPASSWD` sul binario `find` tramite il comando `visudo`. Qualora l'utente necessiti di utilizzare `find` con privilegi elevati per scopi legittimi (es. backup), si raccomanda l'implementazione di script *wrapper* che non consentano all'utente di passare argomenti arbitrari, come `-exec` o `-execdir`.

6.3 VULN-03: CUPS Unauthenticated Remote Registration

Modalità di scoperta:

L'esposizione del servizio è stata inizialmente rilevata tramite scansione automatizzata con Nessus [9] (plugin ID 207864), che ha individuato il demone `cups-browsed` in ascolto sulla porta UDP 631 e l'ha associato alla CVE-2024-47176 [2]. La presenza del servizio è stata successivamente confermata tramite enumerazione attiva con Nmap [7] sulla porta UDP corrispondente.

Origini e Cause:

La criticità deriva da una debolezza nel modo in cui il demone `cups-browsed` gestisce il protocollo IPP (Internet Printing Protocol). Il servizio fa *binding* sull'indirizzo `0.0.0.0:631` e accetta pacchetti UDP non autenticati da qualsiasi sorgente, senza alcun meccanismo di validazione dell'identità del

mittente.

Rischi e impatti sull'asset:

Un attaccante può inviare un pacchetto UDP contraffatto per indurre la macchina bersaglio a registrare una stampante IPP controllata dall'esterno. Quando un utente locale del sistema avvia un *print job* verso tale stampante, il sistema processa direttive PPD (PostScript Printer Description) malevole, ottenendo l'esecuzione di codice remoto (RCE) nel contesto del servizio di stampa.

Nota sull'esito empirico nel test corrente. Il team ha effettivamente caricato e configurato il modulo Metasploit `exploit/linux/cups/cups_ipp_attributes` contro il target, ma la catena di compromissione non si è potuta completare: il trigger finale richiede l'avvio di un *print job* da parte di un utente locale, evento non simulabile in un laboratorio privo di utenti reali e con l'approccio *Black-Box* adottato (che esclude l'utilizzo di credenziali non ancora compromesse). La vulnerabilità è quindi architetturealmente confermata ma non sfruttabile nello scenario operativo specifico, come documentato in *Metodologie Utilizzate PT*. La severity HIGH è mantenuta nella classificazione formale ai fini della valutazione del rischio in scenari di produzione realistici.

Contromisure tecniche adeguate:

Si raccomanda la disabilitazione e disinstallazione del servizio `cups-browsed` tramite il gestore di pacchetti del sistema operativo, in quanto l'host analizzato funge da web server e non necessita di funzionalità di stampa. In alternativa, configurare il *firewall* di sistema per scartare selettivamente tutto il traffico UDP diretto alla porta 631 da reti non fidate.

6.4 VULN-04: Security Misconfiguration

Modalità di scoperta:

La problematica è stata rilevata in fase di scansione del web server tramite Nikto [10], che ha analizzato le risposte HTTP del server identificando l'assenza di tutte le principali intestazioni di sicurezza. La rilevazione è stata corroborata da OWASP ZAP, che ha confermato le stesse evidenze e ha aggiunto la segnalazione di un potenziale vettore XSS su attributi HTML.

Origini e Cause:

L'origine è una configurazione di base e non *hardened* del web server Apache 2.4.29. L'amministratore di sistema non ha esplicitamente dichiarato le direttive di sicurezza (`X-Frame-Options`, `Content-Security-Policy`, `Strict-Transport-Security`, `X-Content-Type-Options`, `Permissions-Policy`, `Referrer-Policy`) all'interno del file di configurazione di Apache, lasciando ai browser dei client il compito di applicare comportamenti predefiniti.

Rischi e impatti sull'asset:

La mancanza dell'header `X-Frame-Options` autorizza i browser dei client ad incorporare l'applicazione all'interno di tag `<iframe>` su domini di terze parti arbitrari, abilitando di fatto attacchi di *UI Redressing* (Clickjacking). Congiuntamente, l'assenza della direttiva `Content-Security-Policy` (CSP) fallisce nel limitare le fonti di script consentiti: un attaccante può quindi sovrapporre script dannosi (vettori XSS) all'interfaccia legittima, intercettando input e sessioni utente direttamente a livello di DOM..

Contromisure tecniche adeguate:

Modificare il file di configurazione di Apache (`apache2.conf` o file in `conf-enabled/`) per includere staticamente le intestazioni di sicurezza in tutte le risposte HTTP. Esempi di direttive: `Header always set X-Frame-Options "DENY"` per prevenire il framing, e una policy CSP restrittiva del

tipo `Header set Content-Security-Policy "default-src 'self';"` per limitare le origini di caricamento delle risorse.

6.5 VULN-05: Sensitive Data Exposure

Modalità di scoperta:

La vulnerabilità è emersa in due punti distinti dell'attività. Durante l'ispezione manuale della pagina `/admin`, è stata individuata nel codice HTML una stringa `passphrase:harder` in chiaro all'interno dei commenti. Utilizzando `steghide` con tale *passphrase* su una delle immagini esposte (`haclabs.jpeg`), è stato estratto un file di testo contenente, in Base64, il nome di una pagina amministrativa non documentata (`superadmin.php`). Successivamente, nella fase di post-exploitation, è stato individuato anche il file `/usr/share/hidden/.passwd` contenente in chiaro la password dell'utente `haclabs` (componente della VULN-02).

Origini e Cause:

La vulnerabilità è di natura concettuale e progettuale: l'applicazione si affida al paradigma della *Security through Obscurity*, nascondendo informazioni sensibili (passphrase, riferimenti a pannelli riservati, password di utenti) all'interno di file accessibili pubblicamente o in posizioni del file system raggiungibili da utenti non amministrativi, in assenza di controlli di accesso espliciti.

Rischi e impatti sull'asset:

Dal punto di vista della kill-chain tecnica, l'estrazione tramite `steghide` dal file `haclabs.jpeg` e la conseguente decodifica Base64 del payload estratto hanno fornito la rotta di navigazione esatta (`/superadmin.php`) verso il componente affetto dalla Command Injection. Successivamente, la visibilità globale in lettura del file `/usr/share/hidden/.passwd` ha permesso all'attaccante di visualizzare tramite comando `cat` la password locale in chiaro, fornendo le chiavi crittografiche necessarie per eseguire il movimento laterale tramite `su` dal contesto limitato di Apache verso un utente di sistema.

Contromisure tecniche adeguate:

Rimuovere immediatamente le immagini contenenti payload steganografici e il file `/usr/share/hidden/.passwd`. L'accesso ad aree amministrative deve essere implementato tramite un meccanismo di autenticazione esplicito (credenziali forti, gestione sicura delle sessioni, eventualmente autenticazione a più fattori), rifiutando qualsiasi richiesta proveniente da utenti non autenticati. Per la gestione dei segreti applicativi è raccomandata l'adozione di strumenti dedicati (vault) anziché file di testo sul file system.

6.6 VULN-06: Information Disclosure

Modalità di scoperta:

La misconfigurazione è stata identificata tramite scansione con OpenVAS [8]. Lo scanner ha inviato pacchetti ICMP di tipo 13 (Timestamp Request) e richieste TCP con opzione Timestamp abilitata, ricevendo in entrambi i casi risposte valide e calcolabili dal target.

Origini e Cause:

L'host bersaglio mantiene la configurazione di default del *kernel* Linux, in cui le risposte ai Timestamp TCP (definiti nelle RFC 1323/7323) e ICMP sono attive per ragioni storiche di diagnostica

di rete e calcolo dell'RTT (Round Trip Time). Le scansioni hanno rilevato la presenza di entrambe le forme di Timestamp, classificate da OpenVAS rispettivamente come CVSS 2.1 (ICMP, CVE-1999-0524) e CVSS 2.6 (TCP).

Rischi e impatti sull'asset:

Il server comunica involontariamente l'orario del proprio orologio di sistema e, soprattutto, l'*uptime* (il tempo trascorso dall'ultimo riavvio). L'esposizione al livello di ICMP Echo *Timestamp Request* (Type 13) non provoca buffer overflow, corruzione del kernel o Denial-of-Service, rimanendo puramente informativa per una profilazione di rete esterna.

Contromisure tecniche adeguate:

Si richiede un intervento a livello di *kernel* e di *firewall*. Per ICMP, configurare `iptables` affinché scarti in modo silente i pacchetti di tipo 13 e 14 in ingresso. Per TCP, disabilitare l'estensione Timestamp aggiungendo la direttiva `net.ipv4.tcp_timestamps=0` al file `/etc/sysctl.conf` e ricaricando le policy con `sysctl -p`.

Capitolo 7

Bibliografia

- [1] The Penetration Testing Execution Standard (PTES).
Disponibile all'indirizzo: <http://www.pentest-standard.org/>
- [2] National Vulnerability Database (NVD) – NIST, *CVE-2024-47176 Detail – CUPS unauthenticated remote code execution*.
Disponibile all'indirizzo: <https://nvd.nist.gov/vuln/detail/CVE-2024-47176>
- [3] MITRE Corporation, *CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')*.
Disponibile all'indirizzo: <https://cwe.mitre.org/data/definitions/78.html>
- [4] GTFOBins, *find – Sudo/SUID Abuse*.
Disponibile all'indirizzo: <https://gtfobins.github.io/gtfobins/find/>
- [5] OWASP Foundation, *OWASP Top 10:2021 – The Ten Most Critical Web Application Security Risks*.
Disponibile all'indirizzo: <https://owasp.org/Top10/>
- [6] OWASP Foundation, *Command Injection Vulnerability*.
Disponibile all'indirizzo: https://owasp.org/www-community/attacks/Command_Injection
- [7] Gordon Lyon (Fyodor), *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*.
Disponibile all'indirizzo: <https://nmap.org/book/toc.html>
- [8] Greenbone AG, *OpenVAS – Open Vulnerability Assessment Scanner*.
Disponibile all'indirizzo: <https://www.greenbone.net/en/openvas/>
- [9] Tenable, *Nessus*. Documentazione disponibile all'indirizzo: <https://docs.tenable.com/Nessus.htm>
- [10] CIRT.net, *Nikto Web Server Scanner*.
Disponibile all'indirizzo: <https://cirt.net/Nikto2>